

File Viewer

Bối cảnh (Context)

Trường Đại học XYZ đang triển khai một trang portal mới cho phép sinh viên tải lên và xem lại các tài liệu bài giảng trực tuyến. Tính năng "View File" nhận tham số là tên của file tài liệu để hiển thị trực tiếp nội dung trên trình duyệt web, giúp sinh viên không cần tải file về máy.

Tuy nhiên, quản trị viên hệ thống đã quên mất rằng máy chủ web đang lưu trữ một file cấu hình rất quan trọng chứa mật mã bí mật (Flag) ở đâu đó sâu trong hệ thống file của Linux (ví dụ: `/etc/flag.txt` hoặc tương tự).

Mục tiêu (Objective)

- **Nhiệm vụ:** Tìm cách thao túng tính năng đọc file của ứng dụng để thoát ra khỏi thư mục chứa tài liệu mặc định và đọc các file hệ thống khác.
- **Vấn đề / Lỗ hổng:** Tính năng đọc file bị lỗi **Directory Traversal** (hoặc **Local File Inclusion - LFI**). Các lập trình viên chỉ đơn giản truyền tên file người dùng gửi lên thẳng vào hàm đọc file của hệ điều hành mà không làm sạch (sanitize) các ký tự đặc biệt.
- **Flag:** Bạn cần đọc được nội dung của file `/flag.txt` hoặc `/etc/passwd` (tùy theo cấu hình bài) để lấy Flag.

Gợi ý (Hints)

- Nếu ứng dụng đang đọc file ở thư mục `/var/www/html/uploads/`, làm sao để bắt nó lùi lại một thư mục?
- Ký tự `../` có ý nghĩa gì trong điều hướng thư mục của hệ điều hành?